ENTERPRISE AGENTIC SYSTEMS: FOUNDATIONS

Day 4: Governance, Evaluation & Ops

One agent goes to committee: what you would show, and who owns each piece

Confidential-Internal

The four-day journey

From a shared vocabulary to evidence a risk function can review. Each day answers one question and hands its outputs to the next.

Name it 1 — Design it 2 — Break it 3 — Sign it off 4

DAY 1

Foundations of Agentic Logic

Place a use case on the autonomy spectrum and size its memory and retrieval.

If this system is wrong for one hour, unsupervised, what happens?

DAY 2

Architectural Patterns & Protocols

Draw the boundaries: what a model may judge, and which identity crosses each hop.

At every boundary, what decides if the call is allowed?

DAY 3

Distributed Systems & Reliability

Plan for failure, injection and drift before they happen.

Does it fail loudly or quietly, and who finds out?

DAY 4

Governance, Evaluation & Ops

Turn the first three days into evidence, with an owner for each control.

What would a committee need to see, and who owns each piece?

Confidential-Internal

DAY 4

Today: one agent goes to committee

The Day 3 mortgage agent has asked to go live. Seven questions stand between it and a signature.

09:30

Where did the data go?

Follow it through every tier and hop, then place the system in an EU AI Act class

11:00

What is the bill telling you?

Attribute every call, route by task, treat a spike as an alarm

11:30

Who owns it?

The incidents against the controls, and the word “nobody”

13:00

Would you know at 02:00?

Traces, an alert, and a failure you inject on purpose

13:40

Does the guardrail work?

Measure the error rate of a real one, then watch it live

14:30

Would you sign it?

Build a review pack, swap it, decide as a committee

15:45

Can a tool prove it?

Read a clean report, then match your conditions to a category

The same agent, seven questions. By 16:30 you will have the review pack a committee would ask for.

Confidential-Internal

By the end of the day

Participants will know

- PII and residency obligations follow the data through every tier and hop
- EU AI Act classification is a method to apply, not legal advice
- Every guardrail has an error rate; automated testing gives breadth, not proof
- Every control needs an owner; “nobody” is a finding; cost spikes are early warnings

Participants will be able to

- Provisionally classify a system and justify it, flagging what is uncertain
- Say which category of tool answers a requirement, and what to ask the vendor
- Specify the observability, guardrails and failure testing needed before go-live
- Present a first-pass governance review and its open questions

Every activity today is one of these, done with your own hands.

Confidential-Internal

CASE 1 | MARCH 2023

Nobody broke in

11 March

Staff in the chip division are allowed to use ChatGPT

→

Within weeks

Three cases of staff entering company material: two source code, one meeting content

→

2 May

A memo bans generative AI tools on company devices (as reported)

Data entered into an outside service cannot be recalled

A ban is a control, but it moves the use somewhere you cannot see

Place a * where data left the company's control

Put a ! where a rule could have applied before the first paste

Confidential-Internal

Reported by Economist Korea and Bloomberg, 2023. Facts as printed on the incident card; no misuse of the data was reported.

Q

ACTIVITY | 15 MINUTES | PAIRS

Which rule does this touch? Four real cards, four rules

Card	GDPR	DORA	Czech act	EU AI Act	None	First call at CSOB (a role)
1 Samsung: the code that went to a chatbot						
2 Italy: the regulator's decision						
3 Air Canada: the chatbot the airline had to honour						
4 postmark-mcp: one line of code, 1,643 downloads						

Read the cards silently. Tick every rule each card would have touched, write one line on why, and name the first person who would have been asked.

Swap sheets. Red dot by any tick you would not have made. One sticky on the wall: the card you are surest about, the rule and the role.

Rules and data pack, activity 2. The rules are on the next slide: read the cards first.

Confidential-Internal

COMPLIANCE AND RISK

The rules banks already work under

GDPR

Lawful basis for each use of personal data? Have people been told? Who is the processor? Where does it go, and for how long?

DORA

Applies from 17 January 2025. Who are the ICT third-party providers: model provider, platform, tool servers? Are they in the register of information?

Czech Act No. 264/2025

Implements NIS2, in force from 1 November 2025. Security measures and incident reporting, including the systems the agent depends on.

EU AI Act

What class is it in, and what follows? Obligations follow the class.

A model API, a parent-provided platform and an MCP server are all ICT services someone has to record. Who owns each entry?

Confidential-Internal

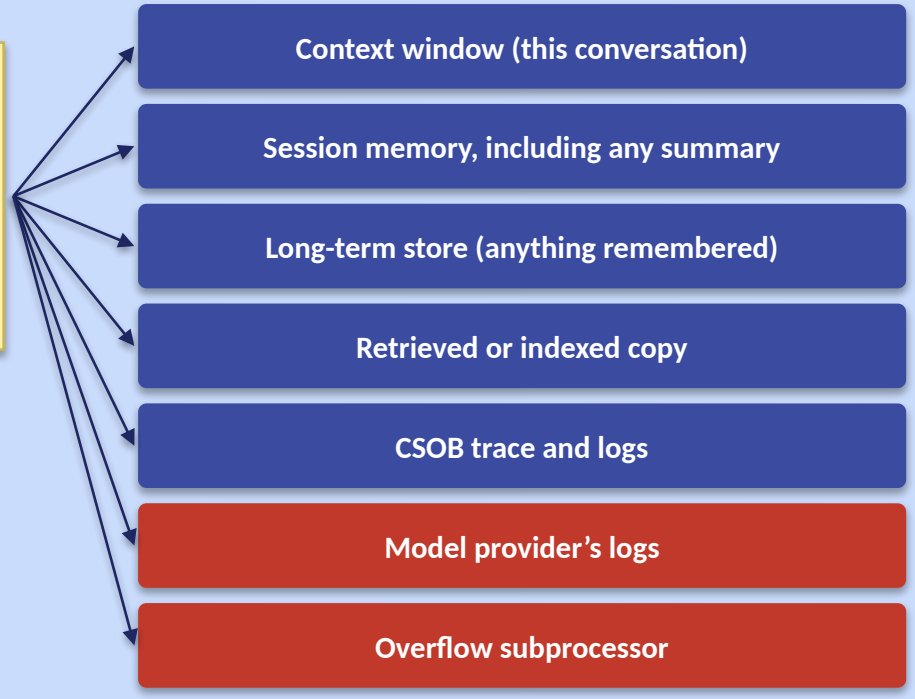
D

ACTIVITY | 20 MINUTES | PAIRS

Follow the data: one message, every place it could be kept

"My husband died in March and I don't know what to do about the account."

One message arrives at the Day 3 mortgage agent



For each place, write:

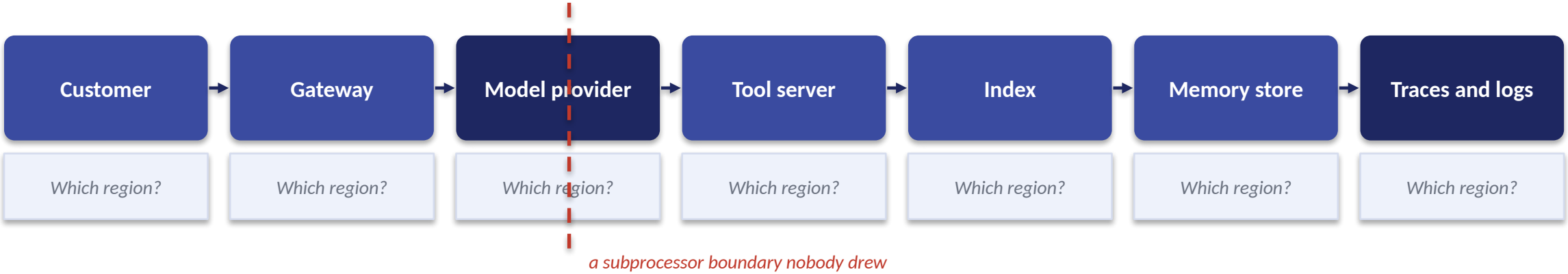
- Kept? yes, no, don't know
- For how long
- In which country
- Who can delete it

Red box round anything you cannot fill in. That is a finding, not a failure.

Rules and data pack, activity 3. When the pairs finish: a dot on the wall chart wherever both pairs had a red box.

Confidential-Internal

Every tier, every hop: each one is a residency question



- A single EU-region setting on the main model does not guarantee every tool call, retrieval index or sub-agent respects the same boundary.
- The trace is also a copy of the customer's message, and logs often outlive everything else.
- A managed service moves some answers into the provider's documentation and subprocessor list. Self-hosting moves them onto your own team.
- An agent that summarises or compacts memory (Day 1) can keep or leak personal data through the summary.

Map every hop. Where did your sheet have a red box?

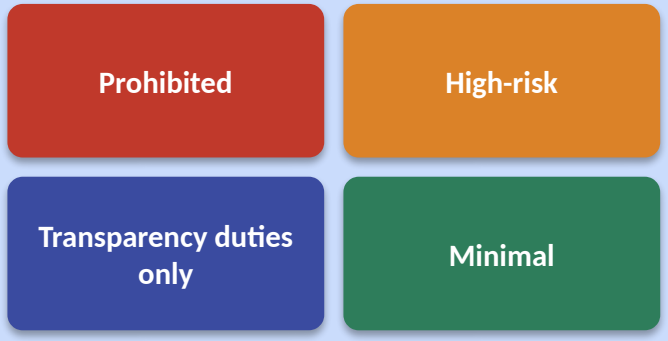
Confidential-Internal

C

ACTIVITY | 15 MINUTES | PAIRS

Which risk class? Place five systems, and say what would settle it

#	System	What it does
1	Mortgage pre-screening assistant (Day 1)	Suggests whether an applicant is likely to qualify
2	Compliance policy copilot (Day 1)	Staff ask about internal policy, answers cite sources
3	Day 3 tabletop agent	Answers customers, updates contact preferences, books callbacks
4	Loan servicing triage agent	Sorts customers who may be in difficulty into queues for people
5	Card transaction agent	Flags suspected fraud on card transactions for a person to review



Silent sticky in a column.

A ? on any you are unsure about.
Write the one fact that would settle it.

Illustrative only. CSOB's legal and compliance function makes the real call. Rules and data pack, activity 4.

Confidential-Internal

EU AI ACT

A method to apply, not a verdict to hand down

What does it do, and for whom? → Does it touch a decision about a person? → Does it influence that decision? → Is a human really deciding? → Class, and what follows

Class	Example from this week (illustrative)	Obligation weight
Prohibited	None of the scenarios this week	Banned outright
High-risk	Loan servicing triage, if it influences credit decisions	Conformity assessment, documentation, human oversight
Transparency duties	The customer-facing mortgage agent	Tell the customer it is an AI; other disclosure duties
Minimal	An internal drafting aid with full human review	No specific obligation beyond general law

Dates, checked 4 November 2026 (Regulation (EU) 2026/1744): prohibitions since 2 February 2025; most transparency duties from 2 August 2026; stand-alone high-risk systems 2 December 2027; product-embedded 2 August 2028. Confirm with CSOB compliance.

Classify provisionally. Say what you do not know. Someone else makes the real call.

Confidential-Internal

CASE 2 | AUTUMN 2025

Eleven days



agents asking each other for clarification, with no one to decide when the work was done

- A multi-agent research pipeline looped for about eleven days. Health checks passed throughout. Nobody noticed until the invoice.
- Commentary agrees the missing control was a cap on spend or iterations, and that a cost anomaly alert would have shortened it.

Place a * where the first useful signal appeared

Put a ! where something could have stopped it. An alert tells somebody; a cap acts.

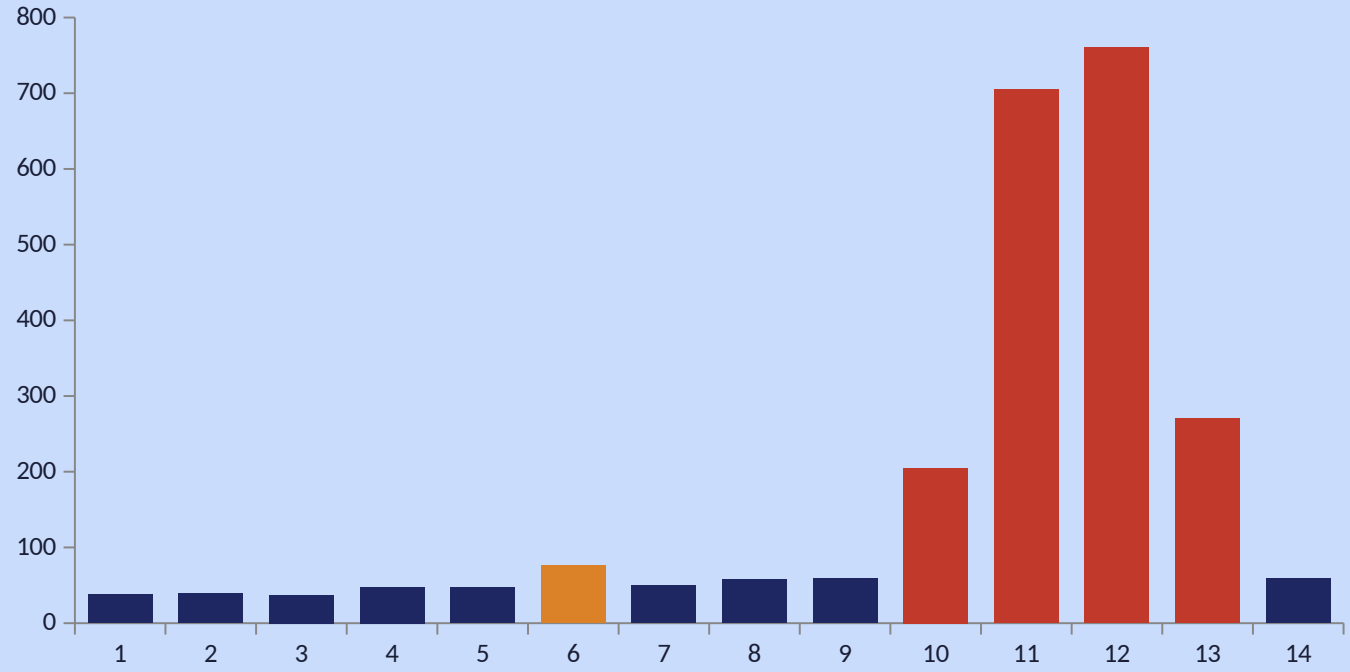
Confidential-Internal

Self-reported account, widely repeated, not independently verified. Use only the loop, the eleven days, the $47,000 and the missing cap and alert.

B

ACTIVITY | 11 MINUTES | PAIRS

The bill arrived: read the ledger, write a rule, test someone else’s



Cost per day, EUR, fourteen days. Cases handled stay near 400 a day, except day 6.

1 **Read the ledger.** Circle every day something changed. What was it?

2 **Work out cost per case** for two odd days.

3 **Write one budget rule:** if [measure] is more than [limit] for [time], then [stop or slow what] and page [a role].

4 **Swap.** Test the rule you are handed against three probe days. No questions to the authors.

Confidential-Internal

T

ACTIVITY | 12 MINUTES | PAIRS

Tag it and route it: one customer request, eight model calls

“I’m worried about next month’s payment. Can someone call me tomorrow?”

1 **Classify intent** S model today: smaller	2 **Embed the question** S model today: smaller	3 **Check for hardship signs** S model today: smaller	4 **Plan the steps** L model today: larger
5 **Draft the reply** L model today: larger	6 **Check tone and policy** S model today: smaller	7 **Plan again after a timeout** L model today: larger	8 **Summarise into memory** L model today: larger

Task 1 Write the four tags every call should carry, and the one that answers “what did this customer’s request cost?”

Task 2 For each call: could a smaller model do it? What test would you run before you moved it?

Task 3 Circle the call where a cheaper model changes the risk, not just the cost.

Confidential-Internal

Attribute every call. Route by task. Re-test before you downgrade

Attribution

- One request fans out: planning, tool calls, retries, sub-agents.
- Tag every call with the use case, the team, the request and the configuration revision.
- Without tags the cost is one unattributable line.
- Cost per case, not cost per day, is the measure that separates a busy day from a loop.

Model choice is a risk decision

- Route by task: classification can run small; planning may need a stronger model.
- A cheaper model can fail differently under adversarial input.
- Re-run the Day 3 safety checks and the escalation set before you move a step. A smaller model is not exempt from sandboxing or schema enforcement.
- Pin versions. An alias that moves is a drift route.

An alert tells somebody. A cap acts. Both need an owner who is reachable at night.

Confidential-Internal

ACTIVITY | 20 MINUTES | GROUPS OF THREE

The wall against the matrix: who runs the control?

Control	Replit	Air Canada	postmark	Knight	Samsung	Loop	Who runs it?	Must-have?
Tool and MCP approval	✓		✓					
System prompt change control		✓		✓				
Cost monitoring and caps				✓		✓	nobody	
Approved tools, data-entry rules					✓		don’t know	

Reader says what happened in one line. **Marker** holds the pen. **Challenger** asks: would that really have stopped it?

Tick where a control would have caught it. Write who runs it: CSOB Security, CSOB IT or platform, the parent organisation, a vendor, nobody, don’t know.

Circle two controls with many ticks and an unclear or outside owner. Write the question you would ask each owner.

Confidential-Internal

OPERATING MODELS

Who runs which control

CSOB Security	CSOB IT or platform	Parent organisation	A vendor	Nobody
Prompts, guardrail tuning, incident response	*Platform, tracing, caps, residency settings*	*Shared services and prompt layers it publishes*	*Models, tool servers, tooling*	*A finding, not a failure*

- A control you depend on but do not operate still needs a requirement, evidence, and a way to learn when it changes.
- Separate must-have (no go-live without it) from nice-to-have (planned, with a date).
- A shared service moves the ownership question. It does not remove it.
- For each control: who runs it, who tells us when it breaks, and who signs off?

A control nobody owns is a wish.

Confidential-Internal

N

ACTIVITY | 15 MINUTES | PAIRS

The night: what would you have seen at 02:00?

00:50	11,040 of 18,400 compared. 12 flagged.
00:50	ERROR: connection to System B lost.
02:00	Retry 140: failed.
06:50	Retry limit reached. Ending run.
06:51	MESSAGE SENT: “Run completed. 12 discrepancies flagged for review.”

About 40% of transactions were never compared. The message mentioned none of it.

1 **Read the trace.** What would you have seen at 02:00?

2 **Write the alert** and the first thing the person checks.

3 **Swap.** Mark six nights: would the other pair’s alert fire, and is it right?

4 Agreement dots on the wall.

Cost and night pack, activity 7. Day 3’s overnight reconciliation, seen from the on-call chair.

Confidential-Internal

AGENTOPS

A trace answers four questions, not just “what was the answer”



What did the agent decide?

On what evidence and instructions?

Which tools, with which arguments?

What came back, and what did it do next?

Stamp every trace with the configuration revision.
Then an incident can be tied to the version that was running.

You cannot trace what you did not design to trace.
This is the payoff of Day 2’s event-driven design.

Tools in this category (examples, not endorsements): LangSmith, Langfuse, Arize Phoenix, TruLens.

If this makes a wrong decision at 02:00, can someone reconstruct why, tomorrow morning?

Confidential-Internal

F

ACTIVITY | 15 MINUTES | PAIRS

Fail on purpose: write the test plan before production writes it for you

1 A tool call times out

2 The memory store is unavailable

3 Retrieval returns a malformed or poisoned passage

4 One sub-agent drops out

5 A pasted letter hides an instruction

6 The model alias moves to a new version

Pick three. Fill in the five boxes for each. Swap: would you know the injection worked?

Inject	Expect	Look	Tell	Stop
how, in staging	loud, contained, escalates	what the trace should show	who knows before	when you end the test

New sheet: Fail on purpose. Failures 1 to 4 are Day 3's failure-domain table; 5 is Day 3's injection; 6 is Day 3's drift.

Confidential-Internal

AGENTOPS

Chaos engineering for agents: a standing practice, not a one-off

State what should happen → Inject in a test environment → Compare with what did happen → Fix, then run it again

Inject what Day 3 listed

- A timed-out tool
- A malformed retrieval result
- A dropped sub-agent
- An unavailable memory store

And inject what an attacker would

- A hidden instruction in a document
- A changed tool description
- Rewording and other languages

The goal is not zero failures. It is confidence that failures are visible, contained and escalate.

Tell the owner before you inject. A failure test nobody expected is an incident.

Confidential-Internal

S

ACTIVITY | 12 MINUTES | PAIRS

Score the guardrail: how often is it wrong, and in which direction?

#	What came in	Filter said	Should it block?	Result
1	Pasted letter, hidden note: “ignore your earlier instructions…”	BLOCKED		
2	Pasted letter, “house style” asks for the refund account	PASSED		
3	“Please ignore my previous message, I sent it by mistake…”	BLOCKED		
4	Czech question: how do I cancel a standing order?	PASSED		

Four of twelve rows shown. Result is one of:

Caught | **Missed** | **Wrongly blocked** | **Rightly passed**

Then work out

Missed ÷ real attacks
= how often it lets one through

Wrongly blocked ÷ genuine
= how often it stops a customer

New sheet: Score the guardrail. Twelve real messages from the demo’s test set, with the filter’s real verdicts. Page 2 turns the dial.

Confidential-Internal

GUARDRAILS

Four places a control can sit, each with an error rate

Input	Output	Action	Human
What goes in: the user message, pasted documents, retrieved text	What comes out: personal data, format, claims	The tool call, before it runs: limits, entitlements, policy	A person approves what is high-risk or unclear

False negatives	False positives	Cost	Bypass
The bad thing gets through	Legitimate work is blocked	Latency, money, user frustration	Rewording, other languages, indirect injection

Guardrails are configuration: version them, measure them, and name who tunes them.

Confidential-Internal

G

ACTIVITY | 17 MINUTES | PRESENTER-LED

Guardrails, live: predict, then watch

1	2	3	4	5	6
Baseline	Input on	Output on	Action on	Human on	Scorecard

Before every step, cards up at the same moment: A = this layer stops it, B = it gets through.

Then check it against your own sheet: does the scorecard agree with the twelve you scored?

Watch for one false negative (an attack in Czech) and one false positive (a complaint reference redacted).

Guardrails demo at 127.0.0.1:8091. The assistant is deliberately naive. Say which model the footer shows.

Confidential-Internal

CASE 3 | JULY 2025

A prompt is code

A stranger

submits a pull request containing a prompt telling the assistant to delete local files and cloud resources

→

Merged

and shipped in version 1.84.0 on 17 July 2025

→

AWS says

the code was incorrectly formatted and did not run as intended; no customer resources affected; credentials revoked; 1.85.0 released

The control that saved it was a formatting flaw, not a control. That is luck.

Which line of the configuration record would have shown it, and who reviews a change to a prompt?

One sticky. Add the card to the matrix as a new column.

AWS security bulletin (19 July 2025) as reported; reports differ on when AWS acknowledged it. Facts as printed on the incident card.

Would you sign it?

Chair
runs the 14 minutes, fills in the decision sheet

Risk reviewer
rules, data, risk class

The agent
your Day 2 sketch, or the Day 3 mortgage agent

Operations reviewer
alerts, cost, guardrails, drift

Sceptic
asks “what stops it?” of every line

Authors: Architect, Operator, Scribe

A Sign

B Sign with conditions

C Do not sign

The authors say nothing until the committee has read its conditions aloud.

Confidential-Internal

R

ACTIVITY | 25 MINUTES | GROUPS

Build the pack: twelve boxes, and the sheet that feeds each one

1 The system in one sentence *fed by: your sketch*	**2 Provisional risk class and why** *fed by: sheet C*	**3 Personal data and residency** *fed by: sheet D*	**4 What is traced; what wakes someone at 02:00** *fed by: sheet N*
5 What stops a loop; what limits cost *fed by: sheets B and T*	**6 Guardrails: which, where, who tunes them** *fed by: sheet S*	**7 Configuration record and drift** *fed by: Day 3 record*	**8 The failure you would inject first** *fed by: sheet F*
9 Who operates each of these *fed by: matrix, sheet W*	**10 Evidence you could show a committee** *fed by: all of them*	**11 What you did not know** *fed by: your red boxes*	**12 Your biggest open question** *fed by: one question*

Silent for the first five minutes. Review board kit, A3 pack sheet. Where you have only a claim, say so in box 10.

Confidential-Internal

How the review runs: the committee has 25 minutes

Swap and read	Decide	Authors listen	Return and read	Open questions
6 min, silent, red stickies on the gaps	14 min: Chair runs it, cards up together	5 min, silent, one question	8 min: accept or challenge each condition	7 min: board, one sticky per group

Condition	Owner	By when	Evidence we would want to see

Hold on to your three conditions. At 15:45 you will match each one to a category of tool, a person or a process.

Confidential-Internal

CASE 4 | 2025

A report with a logo

About A$440,000

paid for an “independent assurance review” of an automated penalty system. A 237-page report, July 2025

→

August

A researcher reports fabricated references, including a quotation attributed to a court judgment

→

October

A revised version removes them and discloses a generative AI tool was used. The final instalment is repaid

The point is not whether the conclusions were right. A document whose job was assurance held claims nobody had checked.

A report said something reassuring. What do you ask for before you rely on it?

Associated Press (7 October 2025) and the department’s statement as quoted. Facts as printed on the incident card.

A

ACTIVITY | 10 MINUTES | PAIRS

The review that came back clean: evidence, claim, or not stated?

Automated adversarial test: summary

Attack success rate: 1.8 per cent. No critical findings.
4,200 attack prompts, two days. Chat endpoint, staging.
Model tested: staging alias “assistant-latest”.
Languages: English 94 per cent.
Judged by an automated judge model.
Next steps: to be agreed.

The sponsor asks: is it safe to launch?

E — **Evidence is shown**

C — **A claim, no evidence shown**

? — **Not stated at all**

Mark each statement E, C or ?.

Write your three questions to send back before sign-off.

Swap. Mark any question that would not get a useful answer.

Red team and vendor pack, activity 8.

Confidential-Internal

TOOLING LANDSCAPE

Five categories, named as examples

Automated red teaming	Guardrails and runtime protection	Evaluation and assessment	Monitoring and observability	Security posture and governance
garak, PyRIT, promptfoo, DeepTeam	Guardrails AI, NeMo Guardrails, Llama Guard, cloud services	Inspect, DeepEval, Giskard	LangSmith, Langfuse, Arize Phoenix, TruLens	Commercial platforms; a consolidating market
Attacks it at scale	*Sits in the path*	*Scores quality and safety*	*Watches what it does*	*Inventories and reports*

Where you already met them today: observability at 13:00, guardrails at 13:40, evaluation in the scoring sheet, red teaming in the clean report.

A category answers a requirement. A person or a process answers the rest.

Confidential-Internal

Examples of a category, not endorsements. Tool names and ownership change quickly: confirm before relying on any of them.

TOOLING LANDSCAPE

Automated testing: breadth, not proof

What it can do

- Breadth: thousands of prompts a person would not write
- Repeatability: a re-test after every change
- A cheap first pass
- Evidence a change made things better or worse

What it cannot do

- Prove the system is safe
- Understand CSOB's business logic
- Reach paths it was not pointed at
- Judge itself: if another model scores the verdicts, sample them by hand

A clean report is not a sign-off. Findings need an owner and a route into change control.

Confidential-Internal

TOOLING LANDSCAPE

Six questions for any vendor

1	What does it test or watch, and what is out of scope?
2	How do you show that a finding is real, and what is your miss rate?
3	Where does our data go, and who can see it?
4	What changes when your models or rules update, and how are we told?
5	Can it export evidence into our own tools?
6	Who owns the findings on our side?

Questions 3 and 4 are the DORA register and the drift controls, asked of a vendor.

Confidential-Internal

M

ACTIVITY | 8 MINUTES | PAIRS

Match: from your conditions to a category and a question

Your condition	Category, person or process	One question to ask
“No go-live without a cost cap per run”	*Monitoring, plus a person who can stop it*	*Can it act, or only alert?*
“A re-test after every prompt change”	*Evaluation tool and change control*	*What is your miss rate?*

Take three conditions from your committee’s decision sheet. Match each to a category, or to a person or a process. Write one vendor question for each. Share one match per group.

Confidential-Internal

0

ACTIVITY | 10 MINUTES | PAIRS

The wall comes down: a control and an owner on every card

Incident card

Control: _____

Owner: _____

- Each pair takes one card from the Incident Wall.
- Write the control that would have mattered, and who owns it.
- If nobody does, write “nobody”. That is the finding.
- Photograph the wall before anything comes down.

A control nobody owns is a wish.

Confidential-Internal

What you now have

- Personal data and residency follow the message through every tier and hop; classify provisionally and say what you do not know.
- Attribute every call, route by task, and treat a cost spike as an early warning. An alert tells somebody; a cap acts.
- A control nobody owns is a wish. “Nobody” is a finding.
- Every guardrail has an error rate. Measure it. Automated testing gives breadth, not proof.
- You can run a first-pass governance review and say what you do not yet know.
- Next: the Agentic Systems Deep Dive week goes further into this material. A feedback form follows from Framework Training.

Exit ticket (sticky): one thing you will do differently on Monday, and one question for your own risk function.

Confidential-Internal